

Guía Metodológica

Encuesta GDPR – Ciberseguridad, Riesgo y Métricas

1. Propósito de la encuesta

Esta encuesta tiene como finalidad medir el grado de madurez de las organizaciones en la aplicación del RGPD en materia de seguridad del tratamiento, notificación de brechas, gestión del riesgo y uso de métricas, con especial énfasis en el contexto español y europeo. [web:14][web:25][web:28]

Se inspira en:

- El enfoque basado en el riesgo del RGPD (art. 24, 25 y 32).
- Las guías de seguridad del tratamiento de ENISA y AEPD. [web:21][web:25]
- La digest de casos del EDPB sobre seguridad y brechas (arts. 32, 33, 34). [web:14]
- La convergencia con NIS2 y modelos de madurez sectoriales NIS360. [web:22][web:26]
- El mapeo práctico entre RGPD, ISO 27001 e ISO 27701. [web:23][web:27]

2. Ámbito de aplicación

La encuesta está diseñada para:

- Responsables de tratamiento y encargados sujetos al RGPD.
- Organizaciones públicas y privadas con operaciones en España o la UE.
- Sectores críticos sujetos a NIS2, donde los mismos controles soportan RGPD y normativa sectorial. [web:22][web:26]

Puede aplicarse:

- A nivel de organización completa.
- A nivel de unidad de negocio o entidad jurídica específica.
- A nivel sectorial, agregando resultados de múltiples organizaciones.

3. Estructura de la encuesta

La encuesta se organiza en diez bloques:

1. Gobernanza y responsabilidad proactiva.
2. Gestión del riesgo y EIPD.
3. Medidas técnicas y organizativas (art. 32).
4. Notificación de brechas (arts. 33 y 34).
5. Terceros, nube y cadena de suministro (art. 28).
6. Formación, cultura y competencia.
7. Indicadores y métricas.
8. Resultados regulatorios y relación con autoridades.
9. Innovación, IA y nuevos contextos de riesgo.
10. Comentarios cualitativos.

Cada bloque combina:

- Preguntas de opción múltiple con escalas de madurez.
- Preguntas de cuantificación aproximada (porcentajes, rangos).
- Preguntas abiertas para matizar.

4. Lógica de las escalas de respuesta

4.1. Escalas de madurez

Las opciones están diseñadas como una escala implícita de madurez, que puede mapearse posteriormente a valores numéricos (p. ej. 1 a 5). [web:27]

Ejemplo:

- No existe / no se aplica.
- Existencia incipiente / informal.
- Existencia formal limitada.
- Existencia formal consolidada.
- Existencia formal integrada y gestionada con métricas.

Esta lógica permite calcular índices de madurez por bloque y un Índice Global de Madurez (IGM).

4.2. Rango de porcentajes

Las preguntas de porcentaje (0–25 %, 26–50 %, etc.) permiten:

- Evitar pedir cifras exactas que pocas organizaciones conocen sin preparar.
- Dar robustez estadística al consolidar resultados.
- Mapear cada rango a un valor aproximado para análisis cuantitativos.

Ejemplo de mapeo:

- 0–25 % → 0,125
- 26–50 % → 0,375
- 51–75 % → 0,625
- 76–95 % → 0,855
- 96–100 % → 0,98

5. Diseño para comparabilidad internacional

Aunque se orienta al contexto español, la encuesta:

- Emplea categorías alineadas con el texto del RGPD y guías de ENISA. [web:25][web:28]
- Usa conceptos comunes a NIS2 (gestión de riesgos, incidentes, madurez sectorial). [web:22][web:26]
- Se apoya en el lenguaje de ISO 27001/27701, para facilitar su uso en organizaciones certificadas. [web:23][web:27]

Esto permite:

- Comparar resultados entre países de la UE.

- Mapear los resultados con indicadores globales de brechas e incidentes. [web:12]
- Enlazar los resultados con cuadros de mando corporativos y de supervisores.

6. Recomendaciones para la aplicación

6.1. Perfil de la persona que responde

Idealmente, la encuesta debe ser respondida por:

- CISO, DPO/DPD o responsable de cumplimiento de protección de datos.
- Con apoyo, cuando sea necesario, de responsables de TI, continuidad, riesgos y negocio.

Se recomienda:

- Responder en equipo cuando la organización es grande o compleja.
- Dedicarse al menos 60–90 minutos para una respuesta reflexiva.

6.2. Modalidad y soporte

La encuesta puede implementarse:

- En plataforma de encuestas online compatible con RGPD. [web:18][web:19]
- En formato hoja de cálculo o formulario interno.
- En entrevistas estructuradas, guiadas por consultores o equipos internos.

En todos los casos, debe:

- Informarse a los participantes sobre el tratamiento de sus respuestas.
- Minimizar la recogida de datos personales innecesarios. [web:18][web:19][web:29]

7. Cálculo del Índice Global de Madurez (IGM)

El IGM es un indicador sintético que resume el nivel de madurez GDPR–ciberseguridad.

7.1. Asignación de pesos

Se propone asignar pesos a los bloques en función de su relevancia:

- Gobernanza y responsabilidad: 15 %
- Gestión del riesgo / EIPD: 15 %
- Medidas técnicas y organizativas: 20 %
- Notificación de brechas: 15 %
- Terceros y nube: 10 %
- Formación y cultura: 10 %
- Indicadores y métricas: 10 %
- Resultados regulatorios: 3 %
- Innovación e IA: 2 %

Los pesos pueden ajustarse según sector (p. ej. más peso a brechas en salud o finanzas).

7.2. Escalado de respuestas

Para cada pregunta:

- Se asigna un valor entre 0 y 1 según la opción seleccionada.
- Se calcula la media de las preguntas de cada bloque.
- Se multiplica por el peso del bloque.
- Se suma para obtener el IGM global (0 a 1), que puede expresarse en porcentaje.

7.3. Niveles de madurez

Ejemplo de niveles:

- 0,00–0,24: Reactivo – cumplimiento “por accidente”.
- 0,25–0,49: Básico – controles mínimos, alto riesgo residual.
- 0,50–0,69: Intermedio – estructura razonable, lagunas relevantes.
- 0,70–0,84: Avanzado – modelo robusto, mejora continua.
- 0,85–1,00: Líder – referencia sectorial, convergencia con marcos globales.

8. Cálculo de ROI de iniciativas de cumplimiento

La encuesta recoge información necesaria para:

- Estimar la inversión en medidas de seguridad y cumplimiento.
- Estimar el coste de incidentes actuales y potencialmente evitados. [web:12][web:28]
- Cuantificar el beneficio de reducción de exposición a sanciones regulatorias e impactos reputacionales.

La plantilla de Excel asociada (ver documento específico) propone:

- Relacionar inversiones por bloque con reducciones de riesgo (probabilidad × impacto).
- Estimar el ahorro neto (beneficios – costes).
- Calcular ROI y payback de iniciativas.

9. Privacidad de las respuestas y uso ético

En tanto hablamos de RGPD, sería irónico no aplicarlo al propio instrumento:

- Limitar datos identificativos al mínimo estrictamente necesario.
- Informar claramente sobre finalidad y plazo de conservación. [web:29]
- Garantizar medidas técnicas adecuadas de seguridad (cifrado, control de acceso). [web:18][web:20]
- Posibilitar ejercicio de derechos sobre los datos recogidos.

10. Interpretación y uso de resultados

Los resultados deben usarse para:

- Identificar áreas prioritarias de mejora.
- Diseñar planes de acción específicos con métricas de seguimiento.
- Comparar la organización con su sector o con medias nacionales/internacionales.

No deberían usarse para:

- Cazar culpables individuales.
- Justificar de antemano decisiones políticas (“la encuesta dice lo que queríamos oír”).

En definitiva, la encuesta es un espejo: puede ser cruel, pero rara vez miente.